



ICT2216/ICT2516C

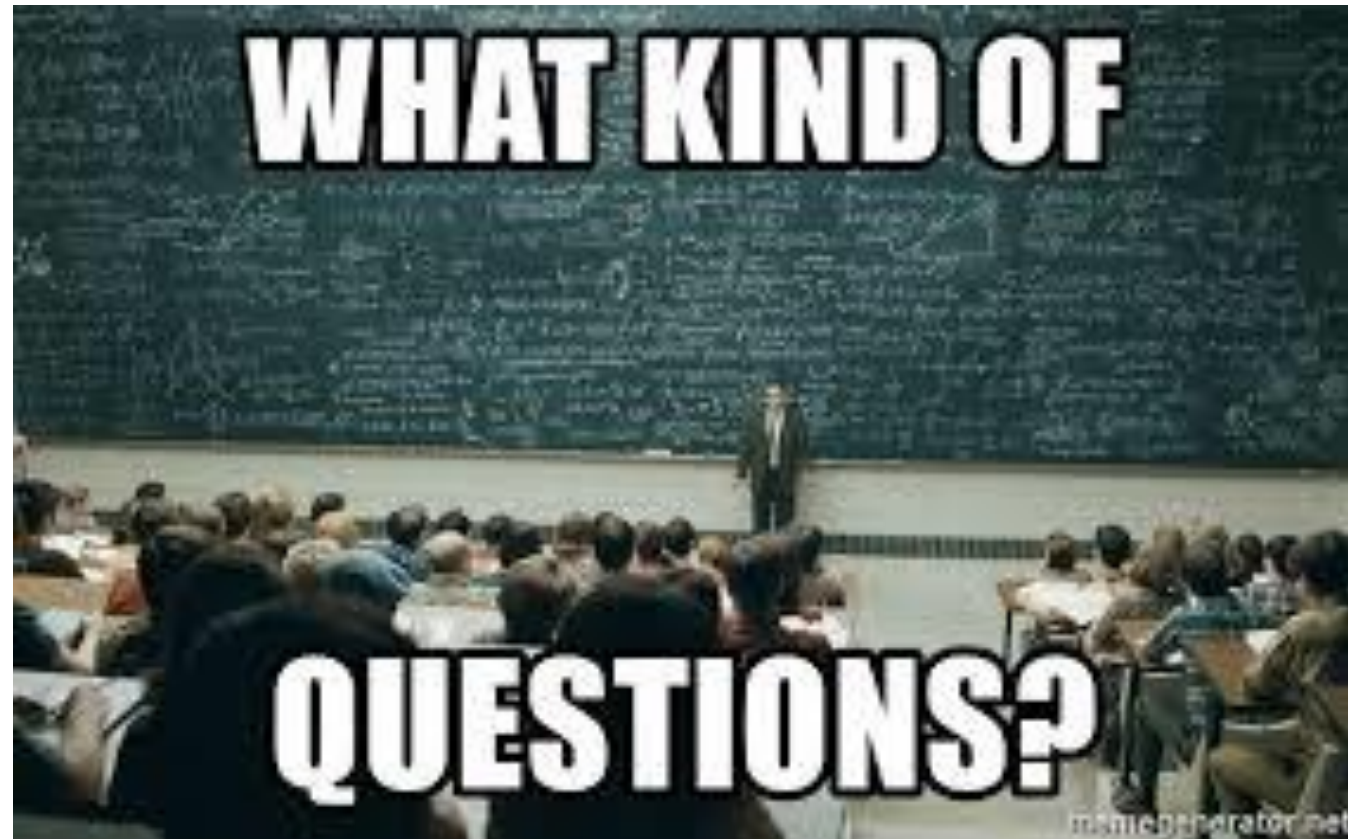
Secure Software Development

Threat Modeling

Raymond Chan & Tram Truong-Huu

Before we start the lecture...

- After we understand the secure requirements...are they enough?



Agenda

- Threat Modeling
 - A more systematic and disciplined way to model security threats
 - Microsoft STRIDE
 - Attack tree
 - CVSS

Introduction to Threat

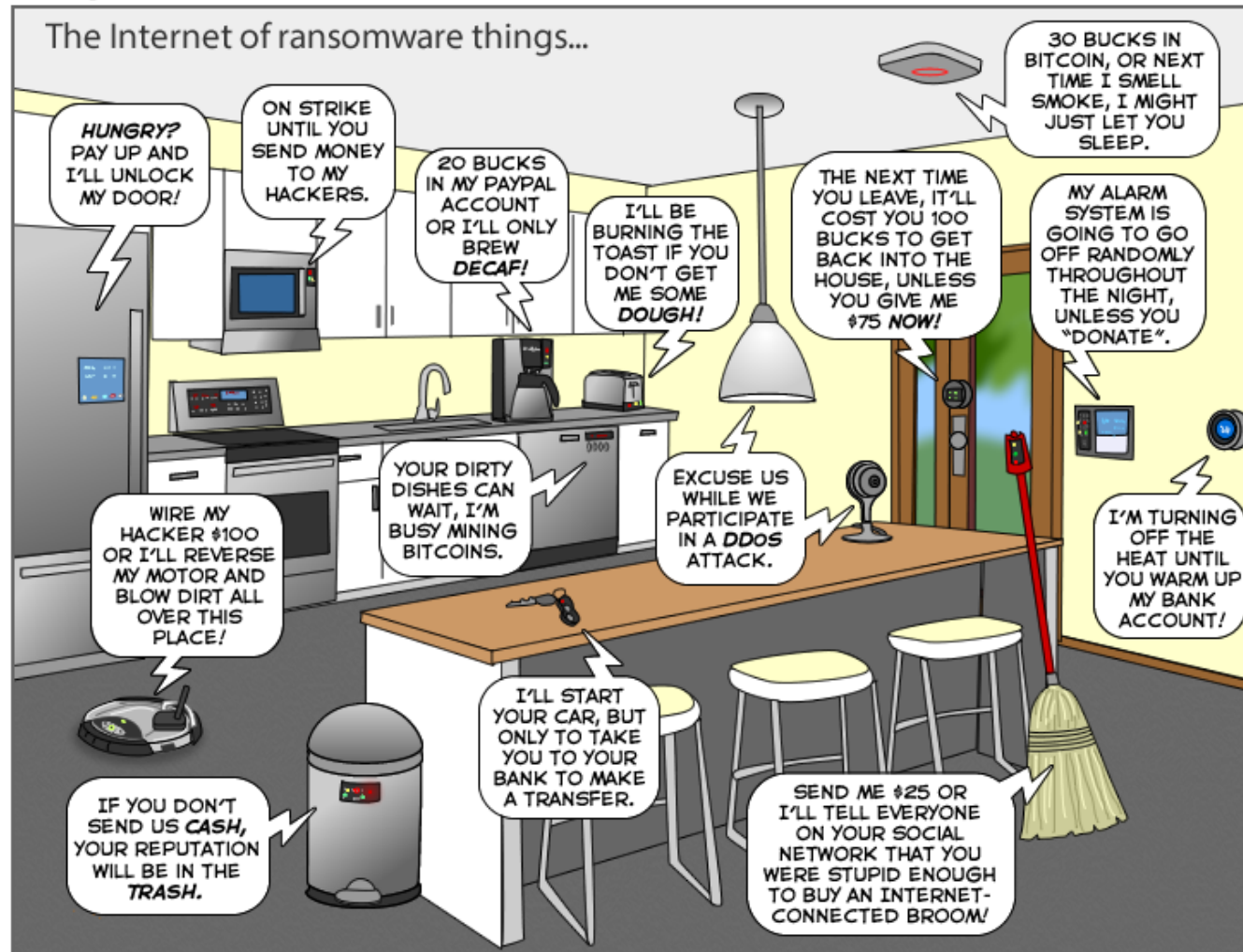
What is a Threat?

- Threats to software are manifold:
 - Disclosure threats against confidentiality
 - Alteration threats against integrity
 - Destruction threats against availability
 - Authentication bypass, privilege escalation, impersonation,
 - Man-in-the-middle attacks, session hijacking, relay attack, injection
 - ...
- Human threats and non-human threats

What is the difference between
Risk and Threat?

I see threats everywhere...

The Joy of Tech™ by Nitrozac & Snaggy



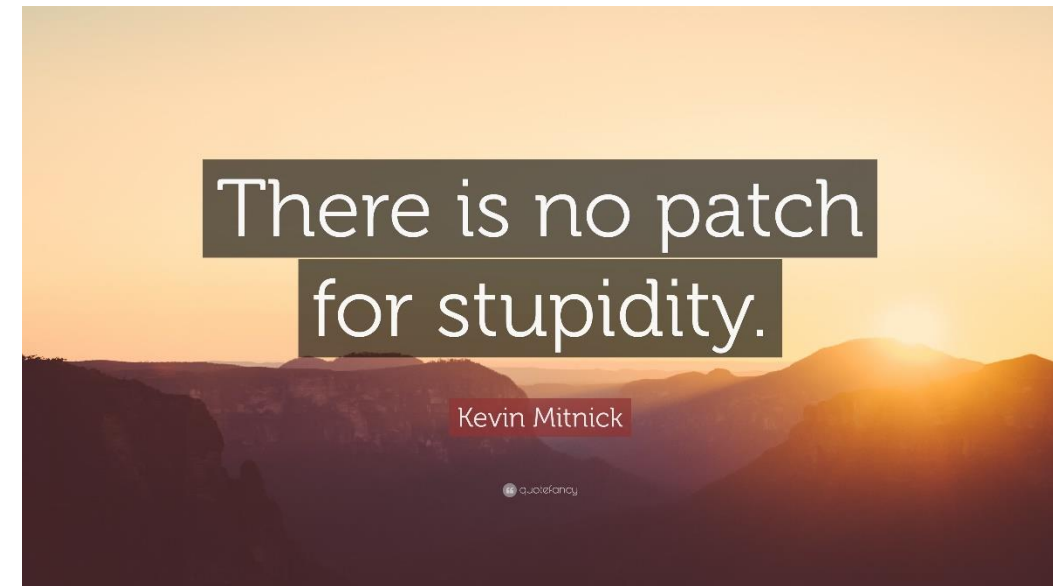
You can help us keep the comics coming by becoming a patron!
www.patreon/joyoftech

joyoftech.com

**WHAT ARE WE GOING TO DO?
CLASSIFY THEM!**

Human threats

- Ignorant User: **The ignorant user** is the one that is often the cause of **unintentional** and **plain user error**.
 - User education is the best defense against this type of threat agent.
- Accidental Discoverer:
 - **An ordinary (normal) user** who **stumbles upon a functional mistake** in the software and who is able to gain privilege access to information or functionality.
 - This user **never sought to circumvent security protection** mechanisms in the first place.



Human threats

- Curious Attacker:
 - **An ordinary user** who **notices some anomaly** in the functioning of the software and decides to **pursue it further**.
- Script kiddies:
 - They are those ordinary users who **execute hacker scripts** against corporate assets without understanding the impact and consequences of their actions.
 - They **do not often hide or know how to hide** their footprint on the software or systems they have attacked.



Human threats

- Insider:
 - One of the most powerful attackers in this day and age is **the insider or the enemy inside the firewall**.
 - These are potentially **disgruntled employees or staff member** within the company that has access to insider knowledge.
- Organized Cybercriminals:
 - These are **highly skilled malefactors** that are paid professionally for using their skills to thwart security protection of software and systems, seeking high financial gain



Human threats

- Third party/supplier: When software is developed outside the purview of one's company control, then **malicious logic and malicious code**, such as logic bombs and Trojan horses, can be **unintentionally or intentional embedded** in the software code, as the software moves through the supply chain.
- National hackers / army: The most powerful hacker in the world.



Non-human threats

- OS Threats
- Malware Threats
- Network Threats
- AI Threats...



Identify threats



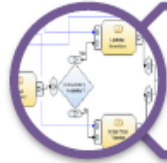
Identify trust boundaries



Identify entry points and exit points



Identify privileged functionality



Identify data flows



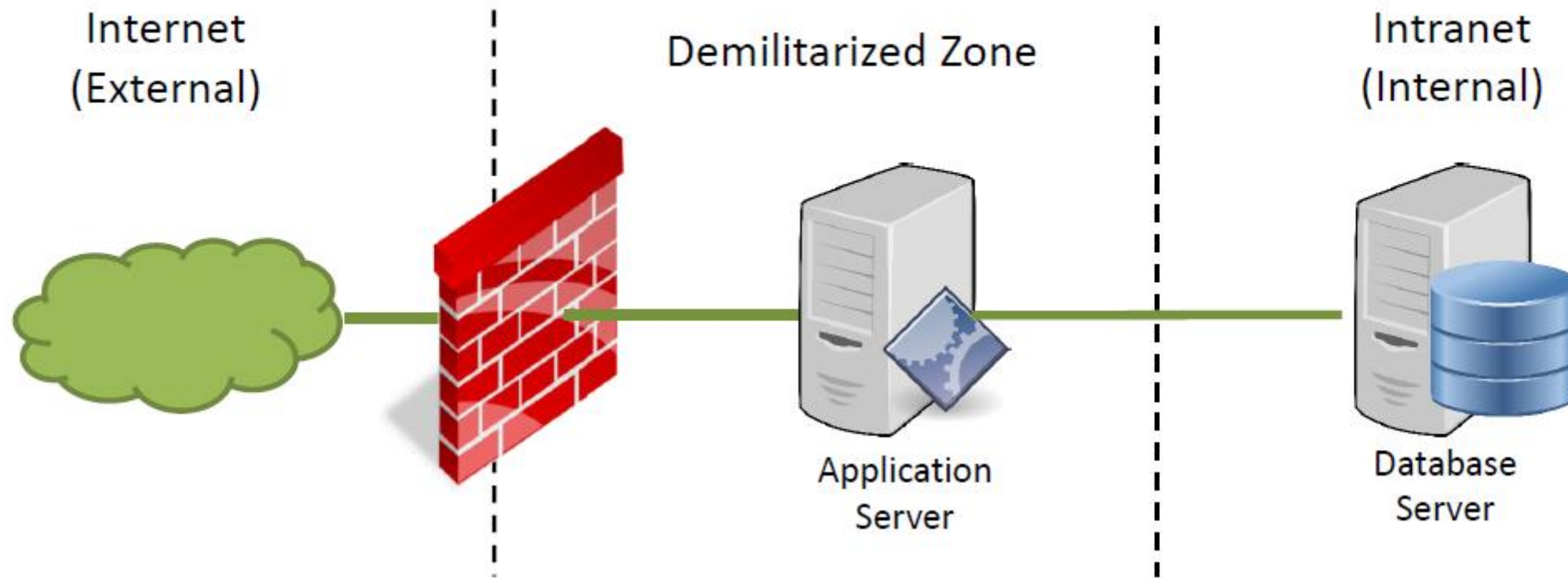
Identify mis-actors (attackers)



Determine potential and applicable threats

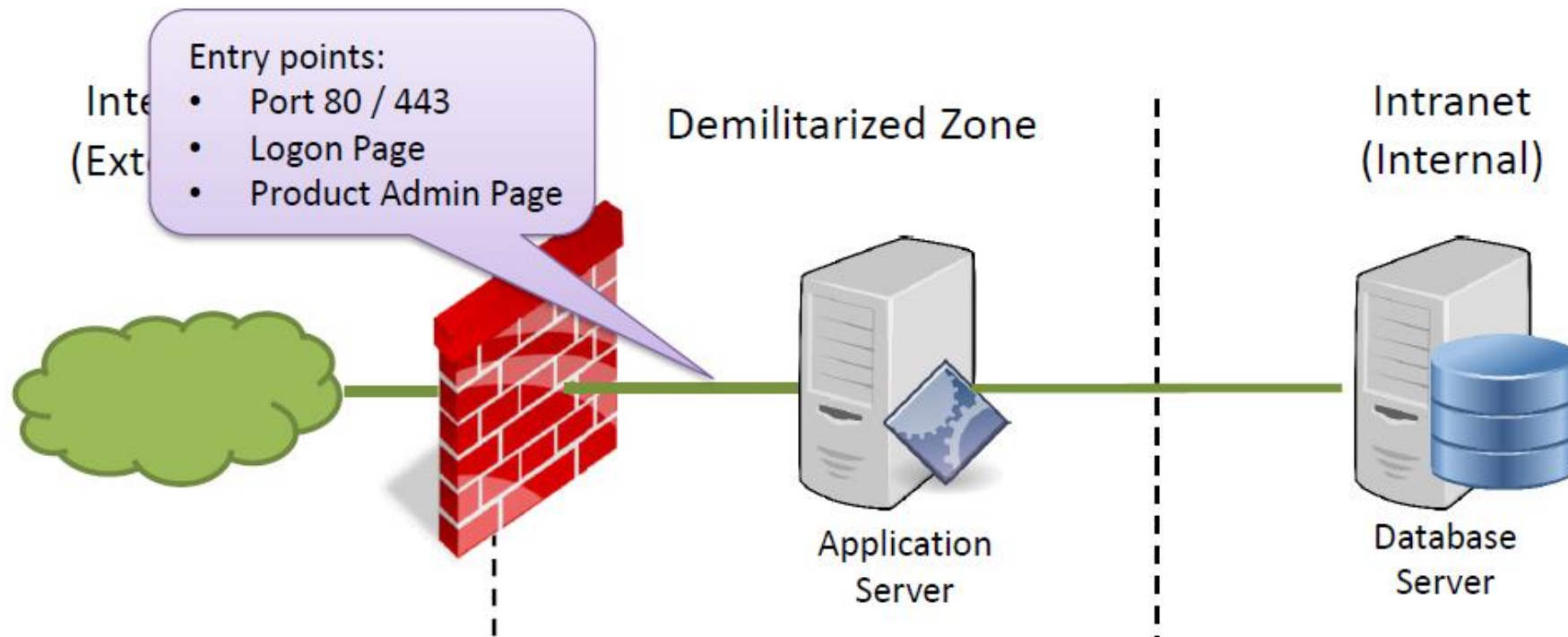
Identify trust boundaries

- A trust boundary is the **point at which the trust level or privilege changes**.
- Identification of trust boundaries is critical to ensure that the **adequate levels of protection** are designed within each boundary.



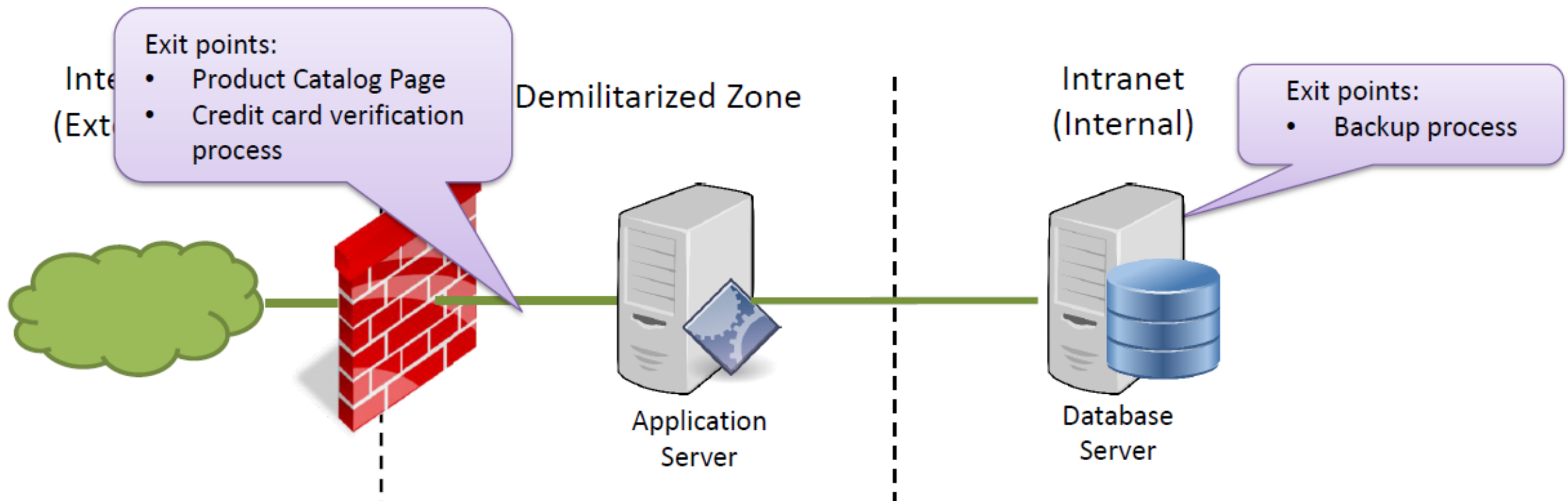
Identify entry points and exit points

- Entry points are those items that **take in inputs**.
- Each entry point can be a **potential threat source**, and so all entry points must be explicitly identified and safeguarded.
- Examples: In a web application: Search page, Logon page, Registration page, Checkout page, Account Maintenance page, etc.



Identify entry points and exit points

- Exit points are those items that **display information** from within the system and processes that **take data out of the system**.
- Exit points can be the **source of information leakage**.
- Examples: in a web application, Search Results page, Product page, View Cart page, etc.



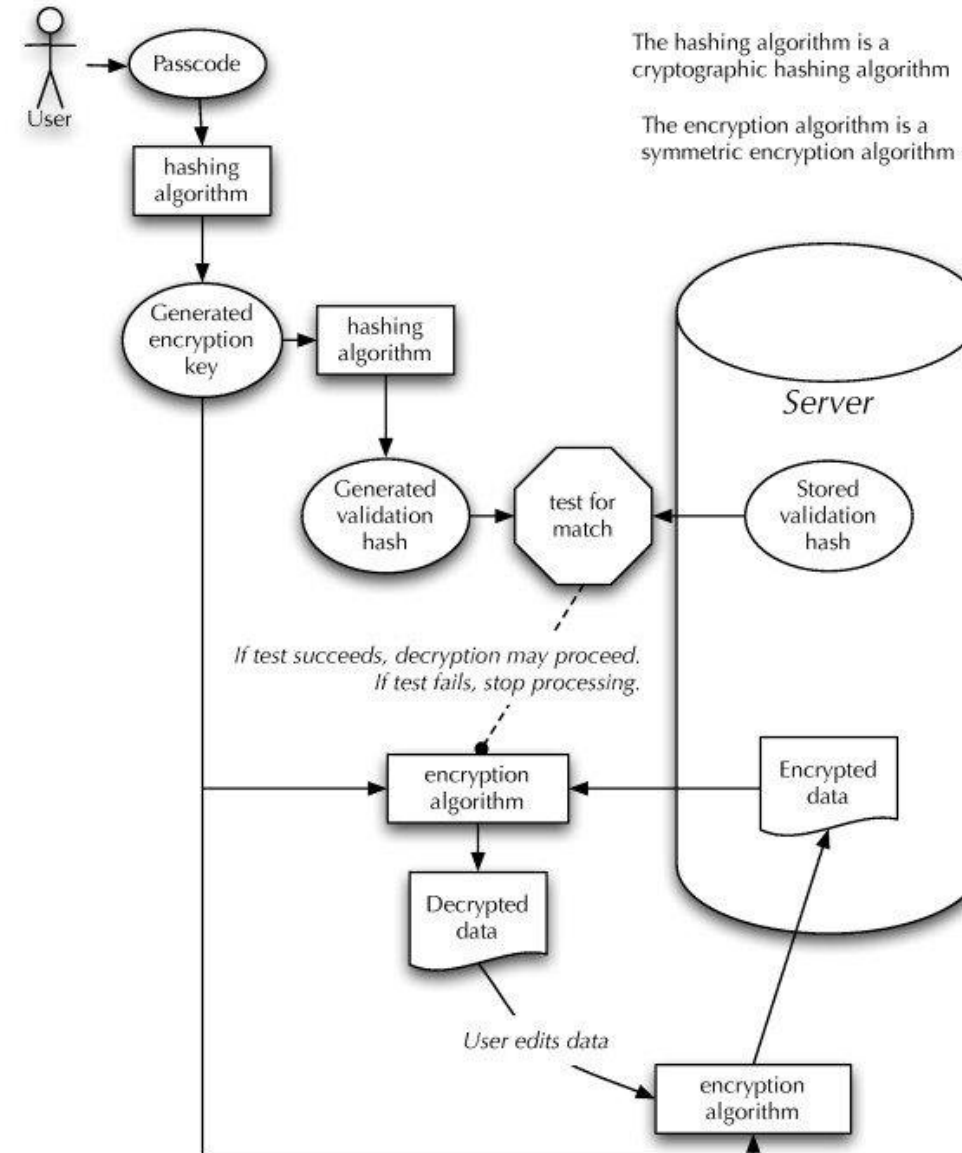
Identify privileged functionality

- To identify any functionality that will **allow elevation of privilege**, or the **execution of privileged operations**, is identified.
 - Examples: all administrator functions and critical business transactions



Identify data flows

- Data flow diagrams (DFDs) assist in the understanding of how the application will accept, process, and handle data as it is marshaled **across different trust boundaries**



Recap: Data Flow Diagrams

External Entity

The external entity shape is used to represent any entity outside the application that interacts with the application via an entry point.



Process

The process shape represents a task that handles data within the application. The task may process the data or perform an action based on the data.



Recap: Data Flow Diagrams

Data Store

The data store shape is used to represent locations where data is stored. Data stores do not modify the data, they only store data.



Data Flow

The data flow shape represents data movement within the application. The direction of the data movement is represented by the arrow.



Privilege Boundary

The privilege boundary shape is used to represent the change of privilege levels as the data flows through the application.

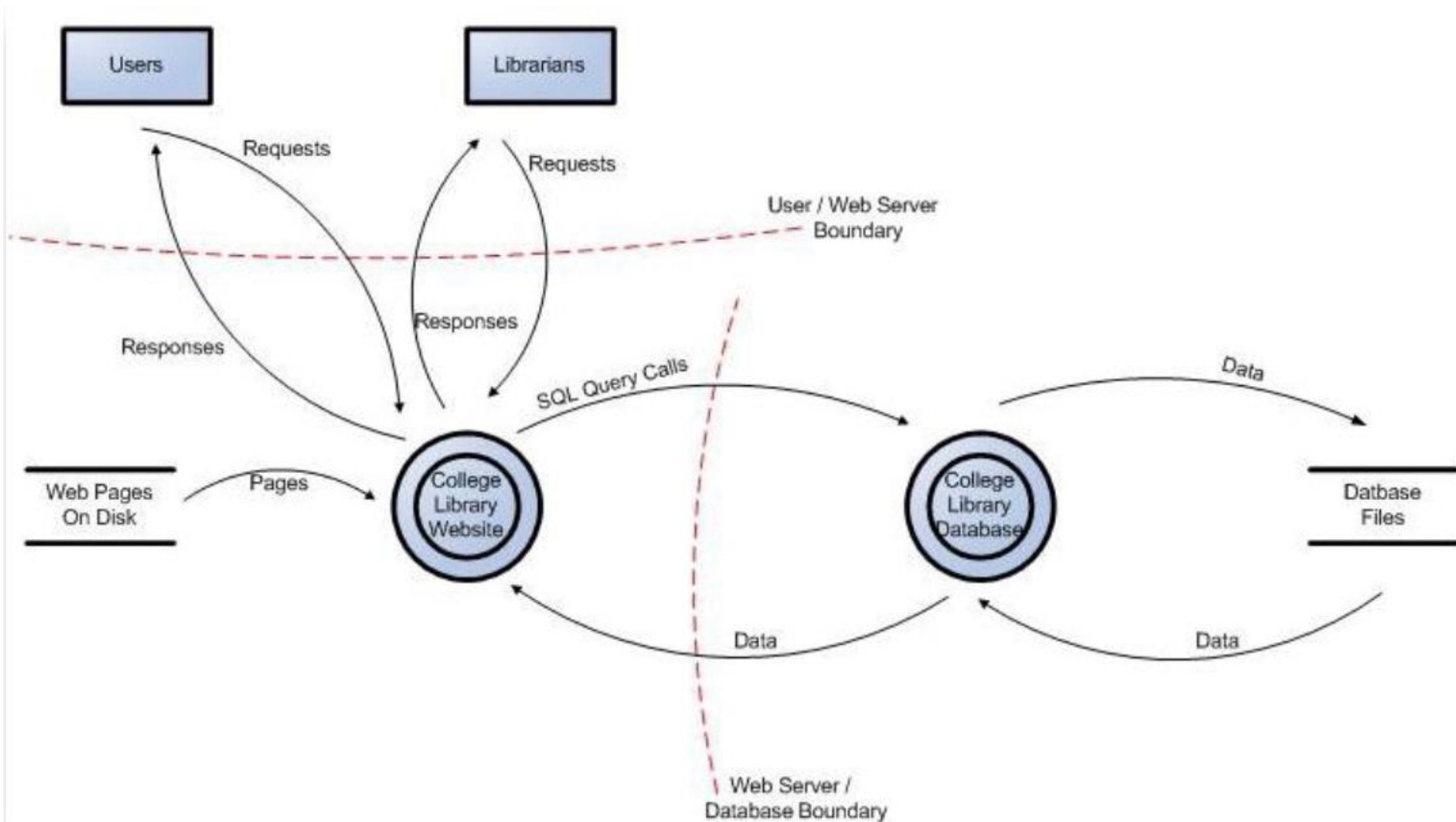


Example: College Library Website

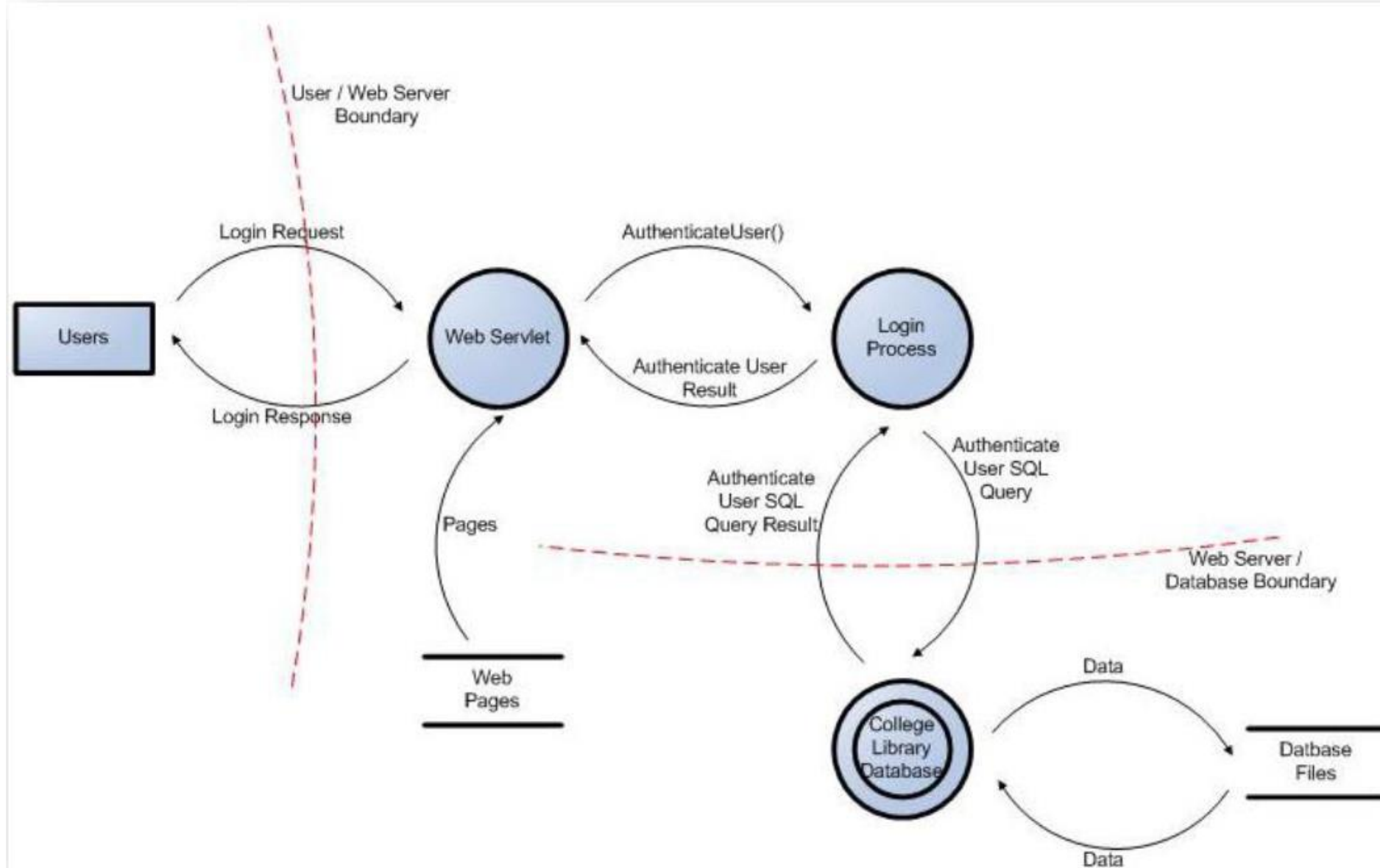
Simple website to provide online service for the library:

- Students
 - Login, search, and request books
- Staff
 - Login, search, and request books
- Librarians
 - Login, add books, add users, search, and request books

Data Flow Diagram for the College Library Website

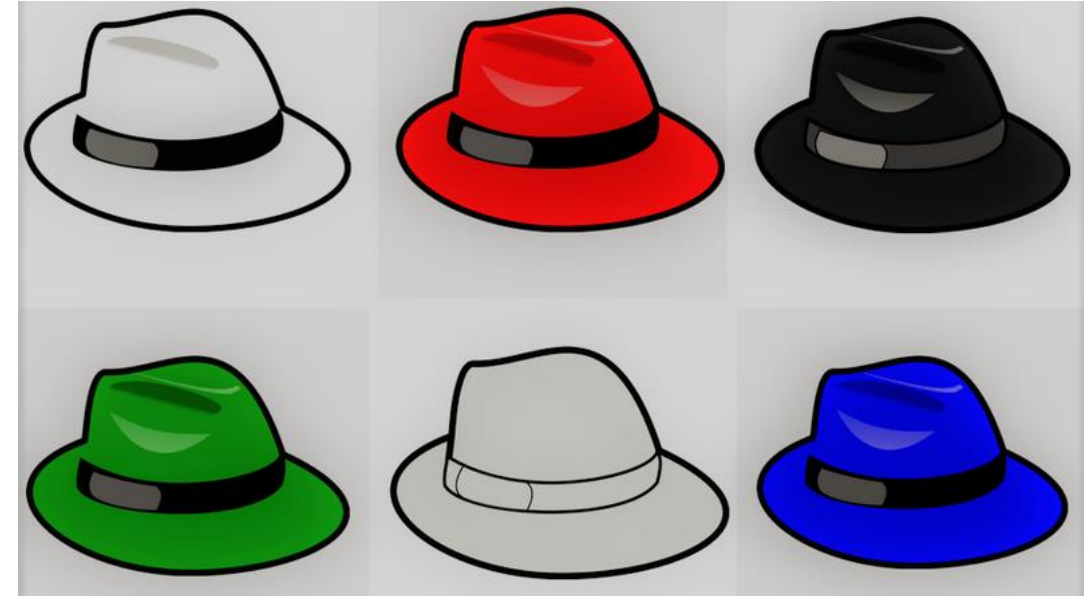


User Login Data Flow Diagram for the College Library Website



Identify mis-actors (attackers)

- Both human and non-human mis-actors
- Examples of **human mis-actors**:
external hackers, hacktivist groups, a
rogue administrator, a fraudulent sales
administrator
- Examples of **non-human mis-actors**:
malware, ransomware

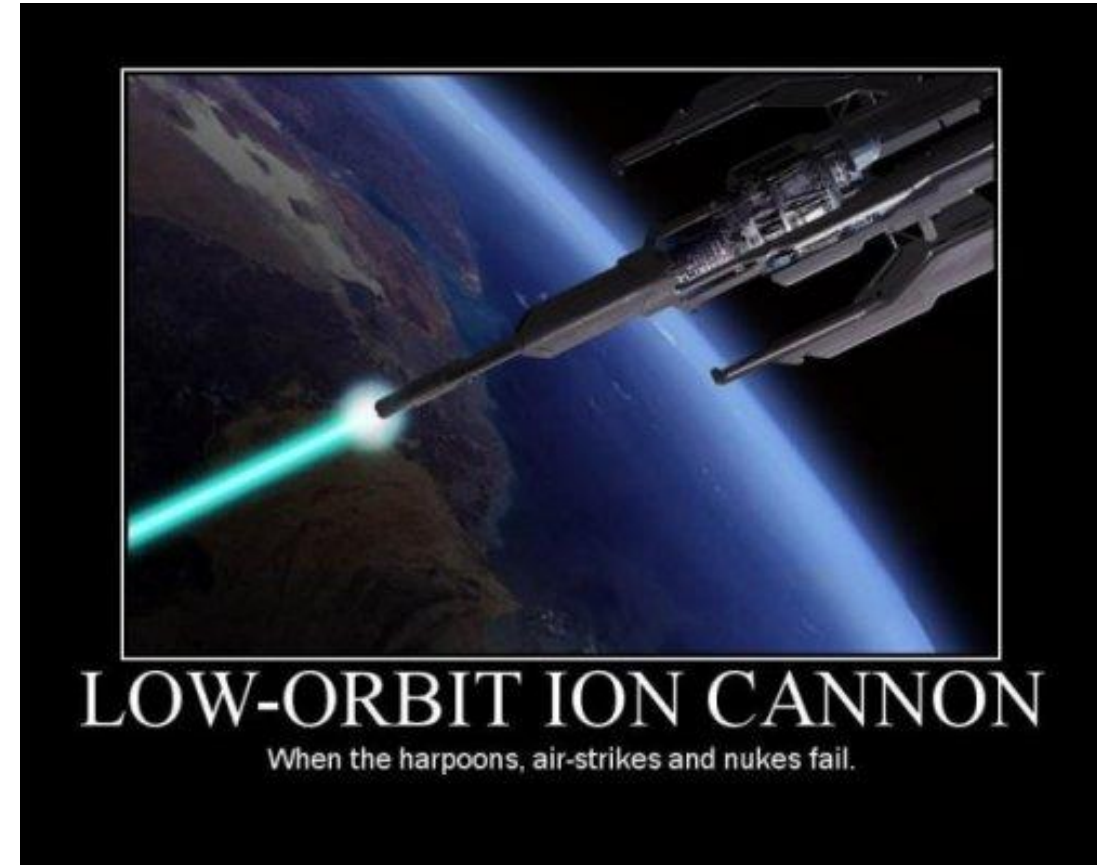


Example: Web mis-actor

- An (anonymous) user who can connect to a service via the Internet can:
 - Measure the size and timing of requests and responses
 - Run parallel sessions
 - Provide malformed inputs, malformed messages
 - ...
- Example attacks
 - SQL injection, XSS, CSRF, buffer overflow

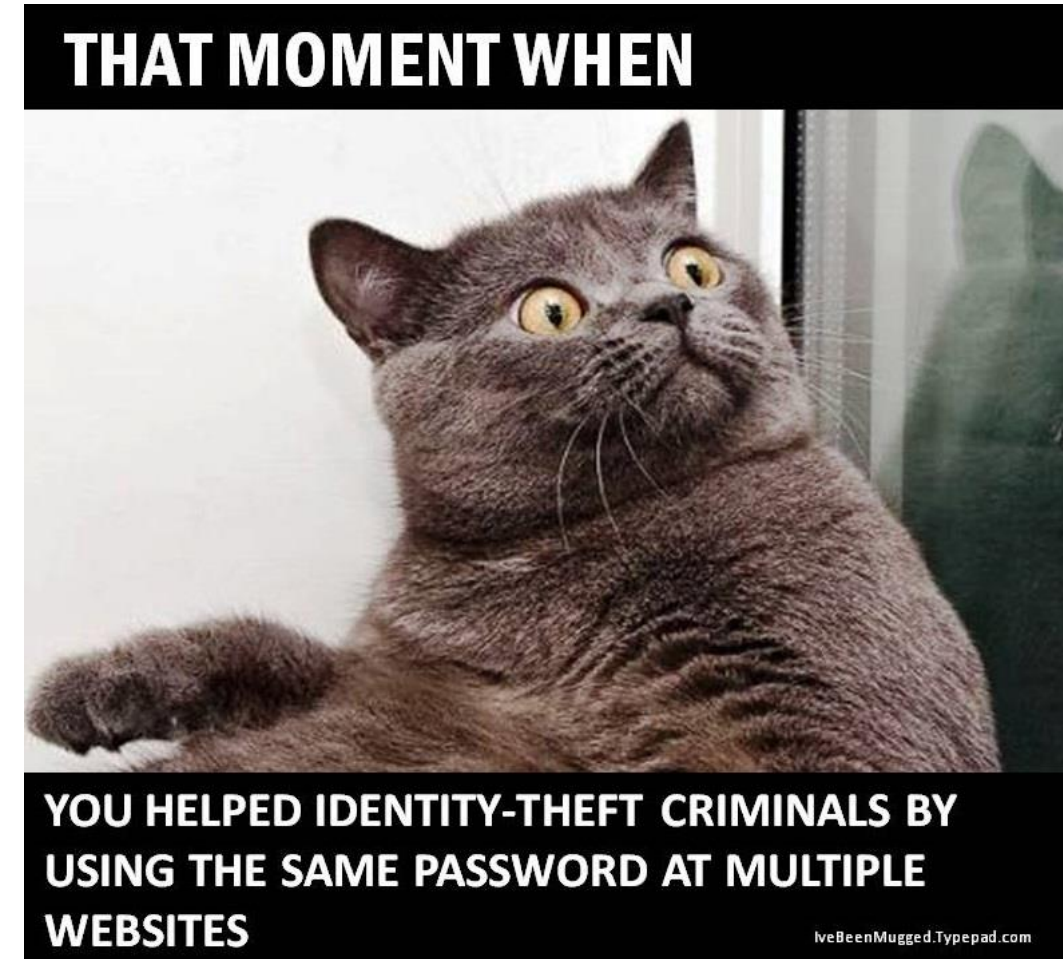
Example: Network mis-actor

- Internet users on the same (unencrypted) network as other users of some services can:
 - Read/measure other messages
 - Intercept, duplicate, modify messages
- Example attacks
 - Session hijacking
 - Denial of service



Example: Co-located mis-actor

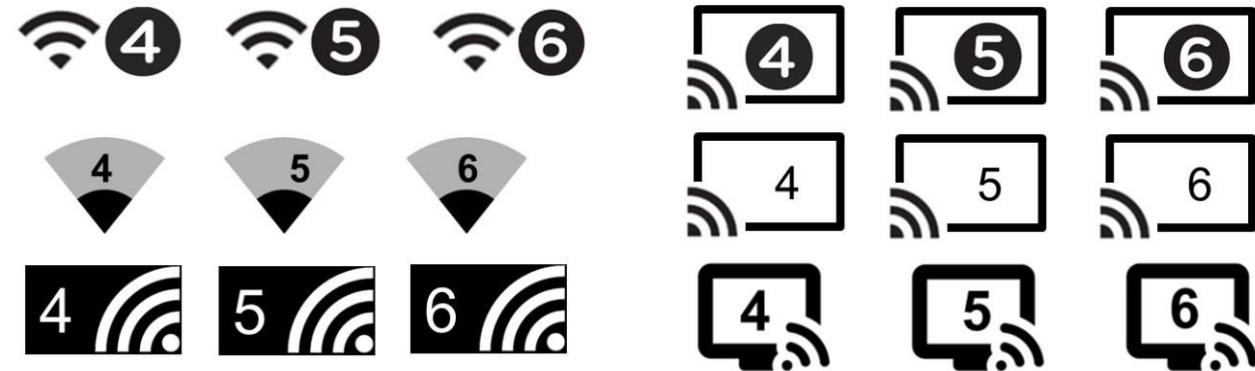
- Internet users on the same machine as other users of same service can:
 - Read/write user's files and memory
 - Snoop key presses
 - Read/write to user's display
- Example attacks
 - Password theft



Different threat models will elicit different responses

- If threat model only includes the Web attacker, message traffic can be considered secure
 - No need to encrypt communications
 - Example: telnet
- Network attackers means message traffic is visible
 - Use encryption
 - Link layer: Secure Wi-Fi
 - Network layer: IPSec
 - Application layer: SSL
- Co-locate attackers
 - Can access local files, memory
 - Should not store unencrypted secrets, like passwords

Sample Generational Wi-Fi incorporation into current UI visuals



Bad Model

- Any assumptions you make in your model are potential weaknesses that the adversary can exploit
- If you assume no network attackers
 - May not be valid because of the prevalence of Wi-Fi networks

INTRODUCTION TO THREAT MODELING

Introduction to Threat Modeling

- Defining security requirements.
- Creating an application diagram.
- Identifying threats.
- Mitigating threats.
- Validating that threats have been mitigated.



Introduction to Threat Modeling

Threat model should include:

- A description / design / model of what you're worried about
- A list of assumptions that can be checked or challenged in the future as the threat landscape changes
- A list of potential threats to the system
- A list of actions to be taken for each threat
- A way of validating the model and threats, and verification of success of actions taken

Introduction to Threat Modeling

- Many Threat-Modeling Methods

Threat Modeling Method	Features
STRIDE	- Helps identify relevant mitigating techniques - Is the most mature - Is easy to use but is time consuming
PASTA	- Helps identify relevant mitigating techniques - Directly contributes to risk management - Encourages collaboration among stakeholders - Contains built-in prioritization of threat mitigation - Is laborious but has rich documentation
LINDDUN	- Helps identify relevant mitigation techniques - Contains built-in prioritization of threat mitigation - Can be labor intensive and time consuming
CVSS	- Contains built-in prioritization of threat mitigation - Has consistent results when repeated - Has automated components - Has score calculations that are not transparent
Attack Trees	- Helps identify relevant mitigation techniques - Has consistent results when repeated - Is easy to use if you already have a thorough understanding of the system
Persona non Grata	- Helps identify relevant mitigation techniques - Directly contributes to risk management - Has consistent results when repeated - Tends to detect only some subsets of threats
Security Cards	- Encourages collaboration among stakeholders - Targets out-of-the-ordinary threats - Leads to many false positives
hTMM	- Contains built-in prioritization of threat mitigation - Encourages collaboration among stakeholders - Has consistent results when repeated
Quantitative TMM	- Contains built-in prioritization of threat mitigation - Has automated components - Has consistent results when repeated
Trike	- Helps identify relevant mitigation techniques - Directly contributes to risk management - Contains built-in prioritization of threat mitigation - Encourages collaboration among stakeholders - Has automated components - Has vague, insufficient documentation
VAST Modeling	- Helps identify relevant mitigation techniques - Directly contributes to risk management - Contains built-in prioritization of threat mitigation - Encourages collaboration among stakeholders - Has consistent results when repeated - Has automated components - Is explicitly designed to be scalable - Has little publicly available documentation
OCTAVE	- Helps identify relevant mitigation techniques - Directly contributes to risk management - Contains built-in prioritization of threat mitigation - Encourages collaboration among stakeholders - Has consistent results when repeated - Is explicitly designed to be scalable - Is time consuming and has vague documentation

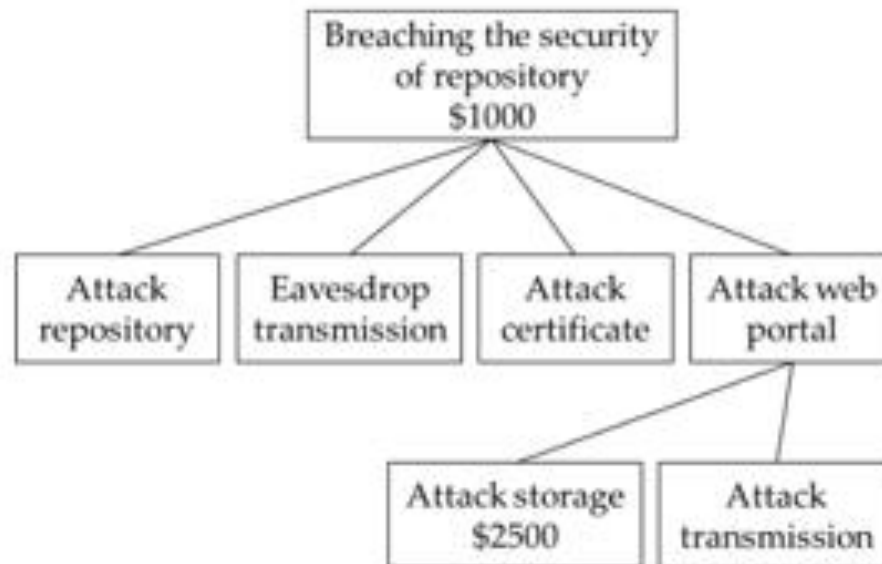
Determine potential and applicable threats

- To identify **relevant threats** that can compromise the assets.
 - It is important that members of architecture, development, test, and operations teams are part of this activity, in conjunction with security team members.
- Two techniques: **Attack trees** and **Categorized threat list**

ATTACK TREE

Attack Trees

- Attack trees are **diagrams that depict attacks** on a system in a tree form.
 - The tree root is the **goal for the attack**, and the leaves are ways to achieve that goal.
- Each goal is represented as a separate tree. Thus, the system threat analysis produces a set of attack trees.



Categorized Threat Lists

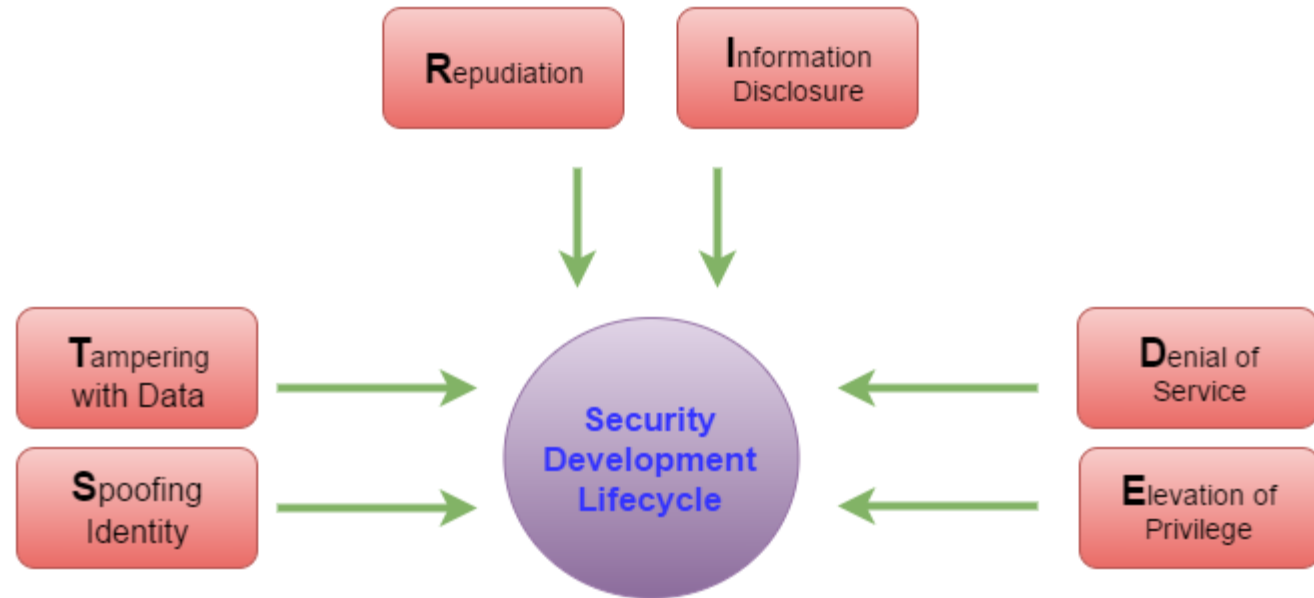
- NSA IAM methodology
- OCTAVE risk modeling
- OWASP Top 10
- CWE Top 25
- **Microsoft STRIDE**
 - STRIDE is an acronym for a category of threats
 - It is a goal-based approach to threat modeling because the goals of the attacker are taken into consideration

Microsoft **STRIDE**

Microsoft STRIDE

Microsoft uses the STRIDE model, which categorizes different types of threats and simplifies the overall security conversations.

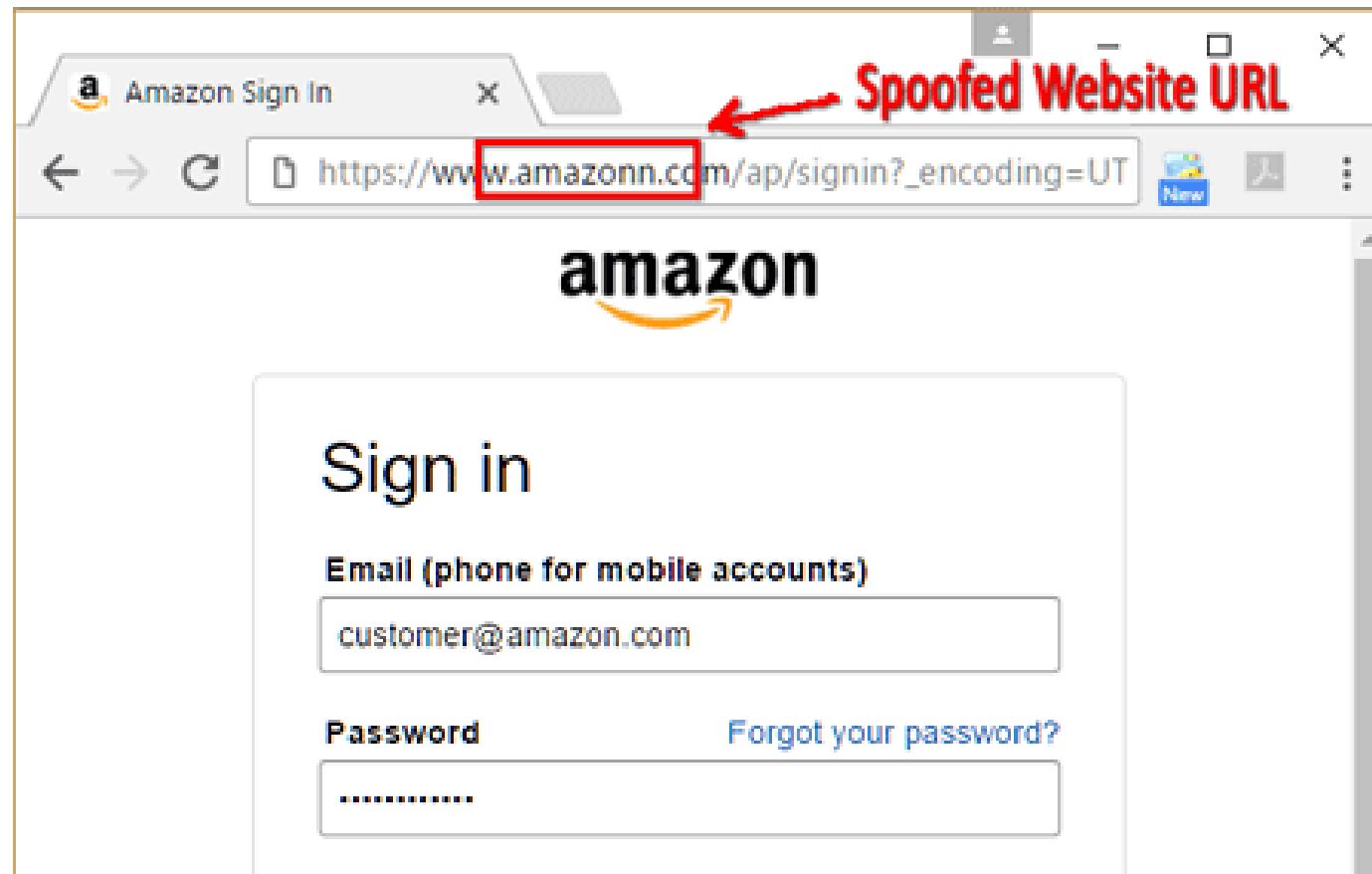
- **S**poofing
- **T**ampering
- **R**epudiation
- **I**nformation Disclosure
- **D**enial of Service
- **E**levation of Privilege



STRIDE Threat Model

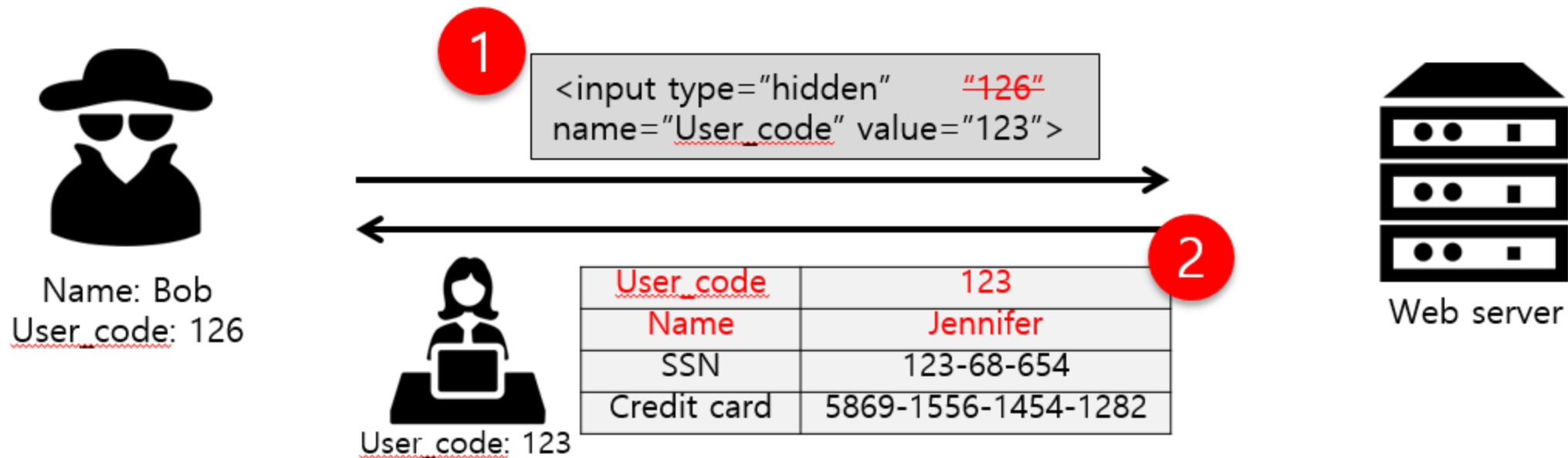
Spoofting

- Involves illegally accessing and then using another user's authentication information, such as username and password?



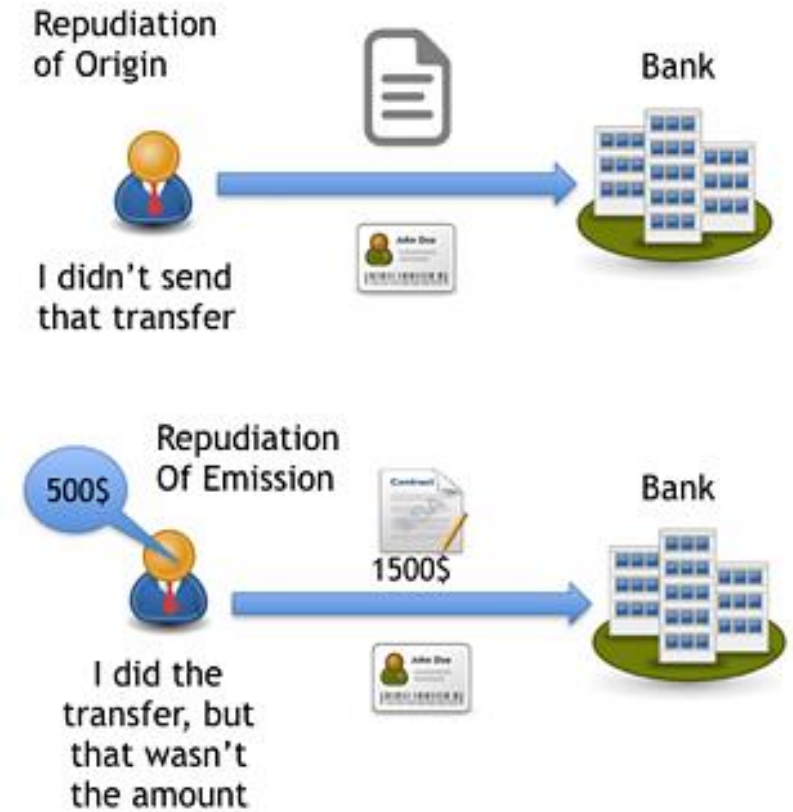
Tampering

- Involves the malicious modification of data.
- Examples include unauthorized changes made to persistent data, such as that held in a database, and the alteration of data as it flows between two computers over an open network, such as the Internet



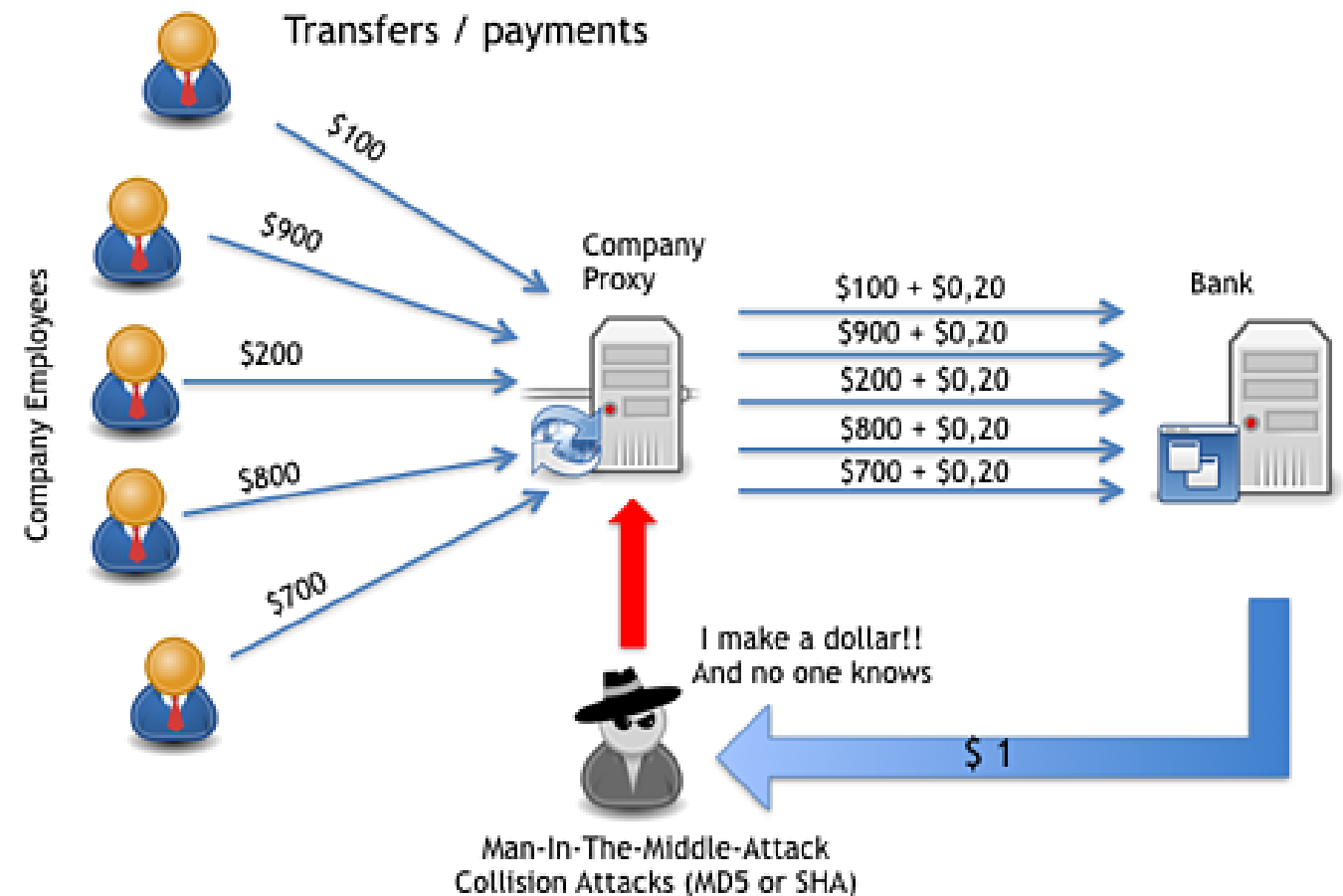
Repudiation

- Associated with users who deny performing an action without other parties having any way to prove otherwise
 - Example: a user performs an illegal operation in a system that lacks the ability to trace the prohibited operations.



Repudiation

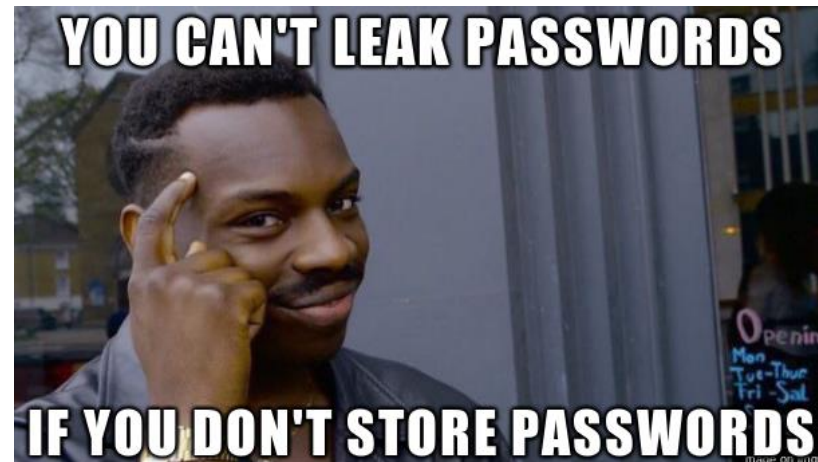
- Non-Repudiation refers to the ability of a system to counter repudiation threats.
 - For example, a user who purchases an item might have to sign for the item upon receipt.
 - The vendor can then use the signed receipt as evidence that the user did receive the package



What is the difference between Repudiation and Non-Repudiation?

Information Disclosure

- Involves the exposure of information to individuals who are not supposed to have access to it
 - Example, the ability of users to read a file that they were not granted access to, or the ability of an intruder to read data in transit between two computers



Denial of Service

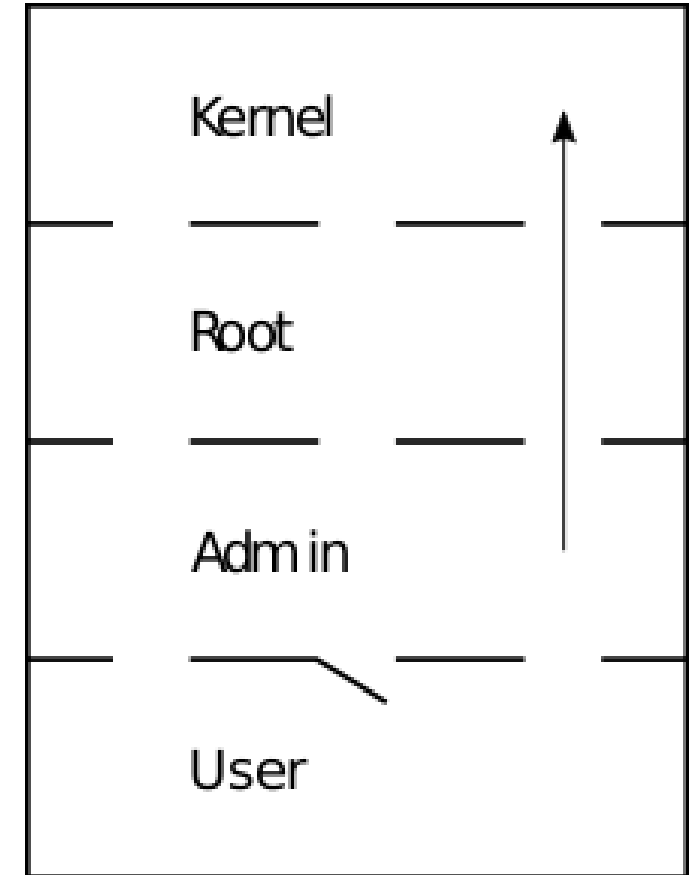
- Denial of service (DoS) attacks deny service to valid users—for example, by making a Web server temporarily unavailable or unusable.
- You must protect against certain types of DoS threats simply to improve system availability and reliability



Do you know what this is?

Elevation of Privilege

- An unprivileged user gains privileged access and thereby has sufficient access to compromise or destroy the entire system.
- Elevation of privilege threats include those situations in which an attacker has effectively penetrated all system defenses and become part of the trusted system itself, a dangerous situation indeed



Reference

- <https://docs.microsoft.com/en-us/azure/security/azure-security-threat-modeling-tool-threats>
- https://insights.sei.cmu.edu/sei_blog/2018/12/threat-modeling-12-available-methods.html
- <https://www.first.org/cvss/specification-document>

QUESTION AND COMMENTS?